

GCP Cloud Security Audit

Cloud Security Audit - NuCore Energy

1.) Summary:

We reviewed your Google Cloud Platform environment to identify potential risks or vulnerabilities and possible improvements.

-Key Takeaways:

- 3 key risks identified.
- Most critical issue: IAM (Identity Access Management).
- Several high-impact fixes are available with minimal effort.

-Overall Risk Level:

- 44/100 - High Risk

2.) Security Score Breakdown:

Category	Score	Risk	Summary
----------	-------	------	---------

<u>IAM & Access</u>	-> 8/25	-> Critical	-> Excessive permissions and shared service account trust increased privilege escalation risk.
-------------------------	---------	-------------	--

<u>Authentication</u>	-> 7/15	-> Moderate	-> MFA existed, but exposed application functions lacked proper access controls.
-----------------------	---------	-------------	--

<u>Storage Security</u>	-> 8/15	-> Moderate	-> Sensitive Finance data had broad authenticated access and weak hardening.
-------------------------	---------	-------------	--

<u>Networking</u>	-> 5/15	-> High	-> Public-facing services and permissive firewall rules increased exposure.
-------------------	---------	---------	---

<u>Logging & Monitoring</u>	-> 5/15	-> High	-> Logs existed, but alerts and proactive monitoring were missing.
---------------------------------	---------	---------	--

<u>Compute Security</u>	-> 2/10	-> Critical	-> Public workloads and shared identities weakened workload security.
-------------------------	---------	-------------	---

<u>Backup & Recovery</u>	-> 0/5	-> Critical	-> No backup or recovery procedures were identified.
------------------------------	--------	-------------	--

3.) Top Risks (Priority issues):

-Risk 1: Excessive IAM permissions & Shared Service Account trust

Importance:

Unnecessary trust relationships were set up across the environment. Due to the creation of multiple high-privilege identities, shared service account usage, and broad cross-project access.

Impact:

An attacker could compromise workloads or an account to do the following:

- Escalate their privileges
- Move across projects
- Access sensitive Financial data

Concern:

Improper IAM and its weaknesses had an amplified impact on all other findings.

-Risk 2: Overexposure of Network and Compute infrastructure.

Importance:

There was an overreliance on permissive firewall rules, the default VPC network configurations. There were public-facing services and weak segmentation.

Impact:

Public exposure increases the likelihood of:

- Unauthorised access attempts
- Reconnaissance and information gathering
- Lateral movement across projects

Concern:

The infrastructure acts as an external entry point into the environment.

-Risk 3: Publicly Accessible Application without Security Controls

Importance:

The GridWatch application has no authentication protocol and the /admin interface is reachable from the internet without any access restrictions.

Impact:

An insecure public-facing application can lead to:

- Credential theft
- Attacker persistence using the application as a foothold
- Gather operational intelligence and enumerate internal resources

Concern:

The application transformed a weak infrastructure into a directly reachable attack surface.

4.) Quick Wins:

High-value and low effort fixes

- Disable Shared-Services account and remove the long-lived key
- Enable Public Access Prevention for the Finance bucket
- Create custom IAM roles
- Use Workload & Workforce Identity Federation
- Activate VPC Peering & Flow Logs where needed
- Track billing costs and resource usage
- Set up Essential Contacts in the environment

5.) Detailed Findings:

IAM & Access

- Observation: 2 identities/principals had broad permissions. The founder and the Shared-Services account had owner privileges.
- Risk: Excessive permissions given to multiple identities gives attackers more options to compromise and gain unauthorised access to the environment.
- Recommendation: Practice least privileged access and only give permissions to the identities that need them to complete specific tasks and nothing more.

Storage

- Observation: The contents of the Financial Reports bucket were accessible via pdf download and an authenticated URL.
- Risk: The financial data is vulnerable due to a lack of access controls including the Shared-Services account having permission to access the contents.
- Recommendation: Disallow other principals from having access to buckets containing sensitive data. And enforce policies on how bucket contents can and cannot be viewed.

Networking:

- Observation: There were no hierarchical policies and only a default VPC network was used for the virtual machine.
- Risk: No policies represent a lack of governance over the environment and business critical resources. The default VPC network does not have hardened security configurations, therefore an attacker could infiltrate the network.
- Recommendation: Create and enforce hierarchical policies and implement hardened security configurations for VPC's aligned with business and security requirements.

Logging & Monitoring:

- Observation: Logs point to the failure to set up TLS and issues with token retrieval in the first two days of the set up. And no alert policies were enabled.
- Risk: Poor server set up or misconfigurations leave the environment exposed for exploitation and unauthorised access. The lack of alert policies decreases visibility into the environment, hindering incident response in the event of a breach.
- Recommendation: Manage server set up defensively and be aware of key configurations that could be exploited. Create and enable alert policies to gain visibility into issues before they escalate.

6.) Recommended Next Steps:

Option 1 (Self-serve):

Follow the recommendations outlined above.

Option 2 (Guided help):

I can assist with implementing the fixes and re-checking your setup.

Conclusion:

The NuCore environment exhibits functional cloud operations. But it requires more effective governance, disciplined identity controls, and mature logging and monitoring practices to limit exposure to unauthorised access and sensitive data compromise.

- Auditing firm: On Guard Security
- Signature: Mr. Clerk
- Professional designation: Cloud Security Engineer and Risk Analyst
- Date of report issuance: May 24th, 2026